IN2120: Kryptografi, Nøkkelhåndtering og PKI

Gjennomgang av eksamensoppgaver

Gruppetime-notat

Høst 2026

Innhold

1 Symmetrisk kryptering (Oppgave 2.1) **2**

2 Diffie-Hellman (Oppgave 2.4) **3**

3 MAC + Digital Signature **4**

4 Postkvantekrypto (Oppgave 2.2) **5**

5 Asymmetrisk kryptering (Oppgave 5.4) **6**

6 Nøkler (Oppgave 19) **7**

7 Kryptoperioder (Oppgave 4.3) **8**

8 Nøkkelsertifikat 2 (Oppgave 16) **9**

9 Nøkkelsertifikat (Oppgave 15) **10**

10 UiO-sertifikatet (sertifikatoppgave) **11**

11 PKI og tillit (Oppgave 6.3) **12**

1 Symmetrisk kryptering (Oppgave 2.1)

Oppgavetekst: Merk påstandene om AES som er sanne.
Poeng: 1 for hver korrekt, −1 for hver feil, 0 for ingen valg, maks 2 totalt.
Velg ett eller flere alternativer.

a) × AES can be used with 2 different keys: one for encrypting and one for decrypting.

b) ✓ AES can be used with different key sizes.

c) × AES can only encrypt messages up to the block size.

d) ✓ AES can be used in different modes, which have different security properties.

a) Feil. AES er symmetrisk kryptering. Det betyr at samme nøkkel brukes til både kryptering og dekryptering. Å bruke to forskjellige nøkler er noe man gjør i asymmetrisk kryptering (som RSA), ikke i AES.
b) Riktig. AES støtter tre nøkkelstørrelser: 128, 192 og 256 bit. Større nøkkel gir sterkere sikkerhet, men tar litt lengre tid å beregne. I praksis er AES-128 ansett som trygt nok for de fleste formål i dag.
c) Feil. AES har en fast blokkstørrelse på 128 bit, men det betyr ikke at meldingen din bare kan være 128 bit lang. Hele poenget med moduser (CBC, CTR, osv.) er at de deler opp lange meldinger i blokker og krypterer dem etter tur. Så du kan kryptere en fil på flere gigabyte med AES uten problemer.
d) Riktig. AES har flere driftsmoduser, for eksempel CBC, CTR, OFB og CFB. Disse har ulike sikkerhetsegenskaper. ECB er et eksempel på en modus som er usikker, fordi identiske klartekstblokker gir identisk chiffertekst, noe som lekker informasjon om innholdet.

2 Diffie-Hellman (Oppgave 2.4)

Oppgavetekst: Angi 3 korrekte utsagn om Diffie-Hellman-algoritmen.
Poeng: 1 for hver korrekt, −1 for hver feil, maks 3, minimum 0.
Velg 3 alternativer.

a) ✓ Brukes for å etablere/utveksle symmetriske nøkler.

b) × Brukes til å kryptere.

c) ✓ Kan potensielt knekkes med kvantecomputere.

d) × Brukes for å etablere/utveksle asymmetriske nøkler.

e) ✓ Støtter ikke autentisering.

f) × Regnes ikke lenger som sikker.

a) Riktig. Diffie-Hellman er en nøkkelutvekslingsprotokoll. To parter (f.eks. Alice og Bob) bruker den for å bli enige om en felles hemmelig nøkkel over en usikker kanal. Denne felles nøkkelen er symmetrisk, altså den samme hos begge.
b) Feil. Diffie-Hellman krypterer ingenting. Den lager bare en delt hemmelighet. Kryptering gjøres etterpå med den symmetriske nøkkelen, typisk med AES.
c) Riktig. Diffie-Hellman baserer seg på det diskrete logaritmeproblemet, som kvantemaskiner (via Shors algoritme) i teorien kan løse. Derfor er DH sårbar for fremtidige kvantecomputere.
d) Feil. Nøkkelen som Diffie-Hellman produserer er en felles, symmetrisk nøkkel. Den lager ikke et asymmetrisk nøkkelpar (offentlig + privat). Selv om protokollen bruker asymmetrisk matematikk underveis, er resultatet en delt hemmelighet.
e) Riktig. Vanlig Diffie-Hellman gir ingen garanti for *hvem* du snakker med. En angriper kan sette seg mellom Alice og Bob og gjøre DH med begge (man-in-the-middle-angrep). Derfor kombineres DH ofte med digitale signaturer for å autentisere partene.
f) Feil. Diffie-Hellman regnes fortsatt som sikker mot klassiske datamaskiner, så lenge man bruker store nok parametere. Det er kvantecomputere som utgjør den fremtidige trusselen, men per i dag er DH i utstrakt bruk (f.eks. i TLS).

3 MAC + Digital Signature

Oppgavetekst: Velg for hver egenskap om den gjelder MAC, Digital Signatur (DSig), begge, eller ingen av dem.
Poeng: 0,5 for hver korrekt, $-0,5$ for hver feil, 0 for ingen valg, maks 3 totalt.

Egenskap	MAC	DSig	Begge	Ingen
Sikrer konfidensialitet				✓
Sikrer integritet			✓	
Sikrer ubenektlighet (non-repudiation)		✓		
Bare mottaker (og avsender) kan autentisere opprinnelsen	✓			
Implementasjonen er basert på hashfunksjoner			✓	
Alle parter kan autentisere opprinnelsen		✓		

Konfidensialitet: **Ingen.** Verken MAC eller digital signatur krypterer meldingen. De sjekker om meldingen er ekte og uendret, men innholdet er fortsatt lesbart for alle. Vil du ha konfidensialitet, trenger du kryptering i tillegg.
Integritet: **Begge.** Både MAC og digital signatur lar mottaker sjekke om meldingen er blitt endret underveis. Hvis noen tukler med innholdet, vil verifiseringen feile.
Ubenektlighet: **Bare digital signatur.** En digital signatur lages med avsenderens private nøkkel, som bare avsender har. Derfor kan ikke avsender i ettertid benekte at de signerte meldingen. MAC bruker en delt hemmelig nøkkel, så begge parter kan i prinsippet ha laget MAC-en, og da kan avsender benekte det.
Bare mottaker og avsender kan autentisere: **MAC.** MAC bruker en felles hemmelig nøkkel. Bare de som har denne nøkkelen kan beregne og verifisere MAC-en. Det betyr at kun avsender og mottaker kan sjekke at meldingen er autentisk.
Basert på hashfunksjoner: **Begge.** MAC (f.eks. HMAC) bruker en hashfunksjon sammen med en hemmelig nøkkel. Digital signatur hasher meldingen først, og signerer deretter hashen med den private nøkkelen. Begge mekanismene bygger altså på hashing.
Alle parter kan autentisere: **Digital signatur.** Hvem som helst med tilgang til avsenderens offentlige nøkkel kan verifisere en digital signatur. Den offentlige nøkkelen er, som navnet tilsier, offentlig tilgjengelig.

4 Postkvantekrypto (Oppgave 2.2)

Oppgavetekst: Hva betyr begrepet "postkvantekrypto"?
Poeng: 1 for riktig svar, 0 for feil svar, 0 for intet valg, maks 1, minimum 0.
Velg ett alternativ.

a) ✓ Kryptoalgoritmer som ikke kan knekkes med kvantecomputere.

b) × Å benytte kvantecomputere til å knekke kryptoalgoritmer.

c) × Kryptoalgoritmer som kan knekkes med kvantekomputere.

d) × Kryptoalgoritmer som benytter kvantecomputere.

a) Riktig. "Post-kvante" betyr "etter kvantecomputere". Postkvantekryptografi er kryptoalgoritmer som er designet for å tåle angrep fra kvantecomputere. Disse algoritmene kjører på vanlige datamaskiner, men er bygget slik at de forblir sikre selv om angriperen har en kvantemaskin.
b) Feil. Dette beskriver heller kvantecomputer-basert kryptoanalyse. Det er et reelt konsept (Shors algoritme kan f.eks. knekke RSA), men det er ikke det "postkvantekrypto" betyr.
c) Feil. Dette er det stikk motsatte. Algoritmer som *kan* knekkes med kvantecomputere er nettopp det postkvantekrypto skal *erstatte*. RSA og tradisjonell Diffie-Hellman faller i denne kategorien.
d) Feil. Postkvantekrypto bruker ikke kvantecomputere. Det er vanlige algoritmer som kjører på vanlig maskinvare. Forskjellen er at de matematiske problemene de bygger på er vanskelige også for kvantemaskiner.

5 Asymmetrisk kryptering (Oppgave 5.4)

Oppgavetekst: Hvilke nøkler benyttes i forbindelse med asymmetrisk kryptering og dekryptering av en hemmelig melding som skal sendes fra en avsender til en mottaker?
Poeng: 0,5 for hver riktig, $-0,5$ *for hver feil, 0 for ubesvart, 1 for alle riktig, minimum 0.*
Velg ett eller flere alternativer.

a) ✓ Privat nøkkel til mottaker

b) × Private nøkkel til avsender

c) × Offentlig nøkkel til avsender

d) ✓ Offentlig nøkkel til mottaker

Tenk på det slik: Alice vil sende en hemmelig melding til Bob.
Kryptering: Alice krypterer meldingen med *Bobs offentlige nøkkel*. Denne er tilgjengelig for alle, så hvem som helst kan kryptere en melding til Bob.
Dekryptering: Bob dekrypterer med sin *private nøkkel*. Bare Bob har denne, så bare Bob kan lese meldingen.
a) Riktig. Mottakers private nøkkel brukes til å dekryptere.
b) Feil. Avsenderens private nøkkel brukes til *signering*, ikke til kryptering av hemmeligheter. Hadde Alice kryptert med sin egen private nøkkel, kunne jo hvem som helst dekryptere med hennes offentlige nøkkel, og da er det ikke hemmelig lenger.
c) Feil. Avsenderens offentlige nøkkel brukes til å *verifisere signaturer*, ikke til kryptering.
d) Riktig. Mottakers offentlige nøkkel brukes til å kryptere meldingen.

6 Nøkler (Oppgave 19)

Oppgavetekst: Flytt inn riktig begrep på riktig plass i teksten.
Poeng: 0,5 for riktig, $-0,5$ *for feil, 0 for ubesvart, maks 3, minimum 0.*
Tilgjengelige ord: *private, krypterer, hemmelige, verifiserer, offentlige, signerer*

Riktig utfylling:
Bob **krypterer** en melding med Alice sin **offentlige** nøkkel. Deretter **signerer** han med sin **private** nøkkel, og sender over meldingen. Alice **verifiserer** signaturen med Bobs **offentlige** nøkkel, og dekrypterer meldingen med sin **private** nøkkel.
Forklaring steg for steg:

1. Bob vil sende en hemmelig melding til Alice, så han krypterer med *Alice sin offentlige nøkkel*. Da kan bare Alice (med sin private nøkkel) lese den.
2. Bob signerer meldingen med sin *egen private nøkkel*. Det beviser at meldingen faktisk kommer fra ham.
3. Alice mottar meldingen. Først verifiserer hun Bobs signatur med *Bobs offentlige nøkkel*. Stemmer signaturen, vet hun at det er Bob som sendte meldingen.
4. Til slutt dekrypterer Alice meldingen med sin *egen private nøkkel*.

Legg merke til mønsteret: offentlige nøkler brukes til å kryptere og verifisere (ting andre gjør mot deg), private nøkler brukes til å dekryptere og signere (ting du gjør selv).

7 Kryptoperioder (Oppgave 4.3)

Oppgavetekst: For hver periode, angi hvilken type nøkkel det gjelder.
Poeng: 0,5 for hver korrekt, $-0,5$ *for hver feil, 0 for intet valg, maks 3, minimum 0.*

Periode	**Hemmelig**	**Offentlig**	**Privat**
Beskyttelsesperiode, symmetrisk kryptering/dekryptering	✓		
Prosesseringsperiode, symmetrisk kryptering/dekryptering	✓		
Beskyttelsesperiode, asymmetrisk signatur/validering			✓
Prosesseringsperiode, asymmetrisk signatur/validering		✓	
Beskyttelsesperiode, asymmetrisk kryptering/dekryptering		✓	
Prosesseringsperiode, asymmetrisk kryptering/dekryptering			✓

For å forstå denne oppgaven er det to ting å ha klart for seg:
Beskyttelsesperioden er tiden hvor nøkkelen aktivt brukes til å *lage* noe (kryptere eller signere). **Prosesseringsperioden** er tiden etterpå, hvor nøkkelen brukes til å *sjekke/lese* det som ble laget (dekryptere eller verifisere).
Hemmelig nøkkel = symmetrisk nøkkel (delt hemmelighet mellom to parter).
Så for hvert scenario, spør deg selv: "Hvilken nøkkel gjør jobben?"

- **Symmetrisk kryptering:** Samme hemmelige nøkkel brukes til alt, både kryptering og dekryptering. Derfor er svaret "hemmelig nøkkel" i begge perioder.
- **Asymmetrisk signatur:** Du *signerer* med din private nøkkel (beskyttelsesperioden). Andre *verifiserer* med din offentlige nøkkel (prosesseringsperioden).
- **Asymmetrisk kryptering:** Du *krypterer* med mottakers offentlige nøkkel (beskyttelsesperioden). Mottaker *dekrypterer* med sin private nøkkel (prosesseringsperioden).

8 Nøkkelsertifikat 2 (Oppgave 16)

Oppgavetekst: I denne oppgaven skal du skrive inn svaret.
Poeng: 1 for riktig; 0 for feil eller ubesvart; maks 2; minimum 0.

Delspørsmål 1

Hva kalles standarden som brukes for public-key nøkkelsertifikater på Internett?
Format: "-.—" (erstatt hver "-" med en bokstav eller et tall)

Svar: X.509
X.509 er standarden som definerer formatet for digitale sertifikater. Sertifikatet inneholder blant annet hvem det tilhører (subject), hvem som signerte det (issuer), gyldighetsperiode, offentlig nøkkel og signaturalgoritme. Når nettleseren din sjekker et HTTPS-sertifikat, er det et X.509-sertifikat den ser på.

Delspørsmål 2

Nevn en asymmetrisk kryptografialgoritme som kan brukes til signering, f.eks. i en PKI-sammenheng. Skriv en, og bare en, i forkortet form.

Svar: RSA (andre godkjente svar kan være **ECC** eller **DSA**)
RSA er den mest kjente asymmetriske algoritmen og brukes mye til digital signering i PKI. ECC (Elliptic Curve Cryptography) er et nyere alternativ som gir tilsvarende sikkerhet med mindre nøkler.

9 Nøkkelsertifikat (Oppgave 15)

Oppgavetekst: Oppgaven omhandler nøkkelsertifikater. Du ser følgende sertifikatsti for inspera.no:

`Amazon Root CA 1` → `Amazon RSA 2048 M03` → `inspera.no`

Poeng: 1 for hvert riktig, −1 for gale svar, 0 for ubesvart; minimum 0.

Delspørsmål 1

inspera.no er et eksempel på: (rot-CA, subjeksertifikat, mellomliggende CA)

Svar: Subjeksertifikat
I sertifikatkjeden er inspera.no helt nederst. Det er endepunktet, altså selve nettsiden som trenger et sertifikat. "Amazon Root CA 1" er rot-CA-en (øverst i kjeden), og "Amazon RSA 2048 M03" er den mellomliggende CA-en.

Delspørsmål 2

Hvem har signert inspera.no? (PKI, Rot CA, Mellomliggende CA, Selv-signert)

Svar: Mellomliggende CA
I praksis signerer nesten aldri rot-CA-en sertifikater direkte til nettsider. Rot-CA-en signerer mellomliggende CA-er, og de mellomliggende CA-ene signerer subjektsertifikatene. I dette tilfellet er det "Amazon RSA 2048 M03" (den mellomliggende CA-en) som har signert inspera.no.
Grunnen til at man gjør det slik er sikkerhet: rot-CA-ens private nøkkel er ekstremt verdifull og holdes helst offline. Ved å bruke mellomliggende CA-er kan man trekke tilbake en mellomliggende CA uten å måtte erstatte selve roten.

10 UiO-sertifikatet (sertifikatoppgave)

Oppgavetekst: Bildet viser utdrag av tjener-sertifikatet for uio.no. Angi hvilke utsagn nedenfor som er korrekt vedrørende sertifikatet.
Poeng: 1 for hver riktig, −1 for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.
Velg opp til 2 alternativer.

a) ✓ Sertifikatet inneholder tjenerens offentlige nøkkel.

b) × Sertifikatet kan brukes til å lage digital signatur.

c) ✓ Sertifikatet kan brukes til å validere digital signatur.

d) × Sertifikatet kan brukes til å dekryptere.

e) × Sertifikatet kan brukes til å kryptere.

f) × Sertifikatet inneholder tjenerens private nøkkel.

Her må man se på hva sertifikatet faktisk inneholder og hva det er satt opp til å gjøre.
a) Riktig. Et X.509-sertifikat inneholder alltid subjektets offentlige nøkkel. Det er liksom hele poenget: binde en offentlig nøkkel til en identitet.
b) Feil. Å lage en digital signatur krever den *private* nøkkelen. Sertifikatet inneholder bare den offentlige nøkkelen. I tillegg, basert på sertifikatets "Key Usage"-felt (som viser "Digital Signature" som formål), er det *verifisering* av signaturer som er tillatt fra klientens perspektiv.
c) Riktig. Med den offentlige nøkkelen fra sertifikatet kan du validere (verifisere) digitale signaturer laget av tjeneren. Sertifikatet har "Digital Signature" som key usage, noe som bekrefter dette.
d) Feil. Dekryptering krever en privat nøkkel, som ikke finnes i sertifikatet.
e) Feil. Ut fra sertifikatets key usage-felt er det ikke satt opp for kryptering. Dessuten er det sertifikatets offentlige nøkkel som er tilgjengelig. Kryptering med offentlig nøkkel er teknisk mulig med RSA, men dette sertifikatet bruker ECC (Elliptic Curve) og er konfigurert for signaturformål.
f) Feil. Et sertifikat inneholder *aldri* den private nøkkelen. Den private nøkkelen oppbevares trygt på tjeneren og deles aldri. Hadde den private nøkkelen ligget i sertifikatet, som er offentlig tilgjengelig, ville hele sikkerheten kollapset.

11 PKI og tillit (Oppgave 6.3)

Oppgavetekst: Angi 4 korrekte utsagn om PKI og tillit.
Poeng: 0,5 for hver riktig, $-0,5$ for hver feil, 0 for ubesvart, 2 for alle riktig, minimum 0.
Velg ett eller flere alternativer.

a) × PKI gjør det mulig å utveksle private nøkler mellom klient og server.

b) ✓ Tillitsmodellen for internett-PKI har flere enn bare en rot-CA.

c) ✓ Et server-sertifikat gir en garanti for at nettsidens domenenavn er autentisk.

d) ✓ En CA sjekker identiteten til eieren av et domene før det utstedes serversertifikat for domenet.

e) × Korrekt validering av et server-sertifikat gir en garanti for at nettsiden er pålitelig.

f) ✓ Server-sertifikater gjør det mulig for klient å autentisere tjener ved opprettelse av en øktnøkkel.

g) × Server-sertifikater gjør det umulig å spoofe nettsider.

h) × Selv-signering av rot-sertifikater gir en garanti for at rot-sertifikatet er autentisk.

a) Feil. PKI handler om å distribuere *offentlige* nøkler på en pålitelig måte, ikke private. Private nøkler skal aldri forlate eieren sin maskin.
b) Riktig. Internett-PKI bruker en modell med mange rot-CA-er. Nettleseren din og operativsystemet ditt har en liste med hundrevis av betrodde rot-CA-er forhåndsinstallert. Denne modellen kalles ofte "silo-hierarki" eller "internett-PKI".
c) Riktig. Når en CA utsteder et sertifikat for f.eks. `uio.no`, bekrefter de at den som ber om sertifikatet faktisk kontrollerer det domenet. Sertifikatet binder domenenavnet til en offentlig nøkkel.
d) Riktig. Før en CA utsteder et sertifikat, gjennomfører de en validering. For et vanlig DV-sertifikat (Domain Validation) sjekkes det at søkeren kontrollerer domenet. For EV-sertifikater (Extended Validation) gjøres en grundigere bakgrunnssjekk av organisasjonen.
e) Feil. Et gyldig sertifikat betyr bare at domenenavnet er autentisk, altså at du snakker med riktig server. Det sier ingenting om innholdet på nettsiden er trygt eller pålitelig. En phishing-side kan ha et helt gyldig HTTPS-sertifikat. Som KrebsOnSecurity-artikkelen i forelesningen viser: halvparten av phishing-sider har hengelås.
f) Riktig. Under TLS-handshake bruker klienten serverens sertifikat til å verifisere at serveren er den den utgir seg for å være. Deretter etablerer de en felles øktnøkkel. Uten sertifikatet kan ikke klienten vite om den snakker med den ekte serveren eller en angriper.
g) Feil. Sertifikater gjør det vanskeligere å spoofe, men ikke umulig. Hvis en angriper klarer å lure en CA eller kompromittere en privat nøkkel, kan de lage et falskt sertifikat. Sertifikater reduserer risikoen, men gir ingen absolutt garanti.
h) Feil. Rot-sertifikater er selvsignerte per definisjon, fordi det ikke finnes noen høyere instans til å signere dem. Selvsigneringen beviser bare at den som har den private nøkkelen lagde sertifikatet. Tilliten til rotsertifikater kommer fra at de er forhåndsinstallert i operativsystemet eller nettleseren, ikke fra selvsigneringen i seg selv.

“Privat” vs. “hemmelig” nøkkel

Disse to begrepene dukker opp om hverandre i pensum, og det er lett å blande dem. Forskjellen er enkel, men den er viktig på eksamen.

En **hemmelig nøkkel** er en symmetrisk nøkkel, altså en nøkkel som to (eller flere) parter deler seg imellom. Begge partene kjenner nøkkelen, og begge bruker den til å kryptere og dekryptere. Den er “hemmelig” fordi den må holdes skjult for alle andre, men den er *delt* mellom partene. Tenk på det som et felles passord som du og kompisen din har avtalt på forhånd.

En **privat nøkkel** er den ene halvdelen av et asymmetrisk nøkkelpar. Den tilhører bare deg, og ingen andre skal noensinne se den. Den andre halvdelen er den offentlige nøkkelen, som hvem som helst kan ha. Privat nøkkel brukes til å signere og dekryptere, mens offentlig nøkkel brukes til å verifisere og kryptere.

Kort sagt: “hemmelig” = delt mellom to parter (symmetrisk). “Privat” = kun din (asymmetrisk). Skillet er spesielt relevant i oppgave 4.3 om kryptoperioder, hvor du må vite om perioden gjelder en hemmelig, offentlig eller privat nøkkel.

Oppsummering: Nøkkelbegreper

Her er en rask oversikt over de viktigste konseptene som dukker opp i oppgavene:

- **Symmetrisk kryptering:** Samme nøkkel til kryptering og dekryptering. Rask, men nøkkeldistribusjon er et problem. Eksempel: AES.
- **Asymmetrisk kryptering:** To nøkler (offentlig og privat). Offentlig nøkkel krypterer, privat dekrypterer. Eksempel: RSA.
- **Hashing:** Enveisfunksjon med fast output-størrelse. Brukes til passordlagring og integritetsjekk. Er ikke kryptering.
- **MAC:** Hash pluss delt hemmelig nøkkel. Gir integritet, men ikke ubenektlighet.
- **Digital signatur:** Hash signert med privat nøkkel. Gir integritet og ubenektlighet.
- **Diffie-Hellman:** Nøkkelutveksling, ikke kryptering. Sårbar for MITM uten autentisering.
- **PKI:** Infrastruktur som binder offentlige nøkler til identiteter via sertifikater.
- **X.509:** Standarden for digitale sertifikater på internett.
- **Sertifikatkjeden:** Rot-CA $\rightarrow$ mellomliggende CA $\rightarrow$ subjektsertifikat.
- **Postkvantekrypto:** Algoritmer designet for å motstå angrep fra kvantecomputere.